Bloque 1: Introducción, Gobernanza y el Ciclo de Desarrollo Seguro

FADENA

Arquitectura Zero Trust y Marcos Corporativos

Ing. Roxana Quiroga Sollinger



MSDL Parte 1

Módulo 2: Arquitectura Zero Trust y Marcos Corporativos

FADENA

2.1 Arquitectura y gobierno Zero Trust

2.2 Microsoft Security Development Lifecycle

2.3 Seguridad en DevSecOps



Módulo 1: Fundamentos de Seguridad en el Software

FADENA

Microsoft Security Development Lifecycle



2.2 Microsoft Security Development Lifecycle

- **La necesidad del SDL**
- **Prácticas del SDL**

  (https://www.microsoft.com/en-us/securityengineering/sdl/practices)
- Integración con DevOps



2.1 Microsoft Security Development Lifecycle

La necesidad del SDL

> *El Ciclo de Vida de Desarrollo Seguro (SDL) es el enfoque que Microsoft utiliza para integrar la seguridad en los procesos DevOps (a veces denominado enfoque DevSecOps).*

https://www.microsoft.com/en-us/securityengineering/sdl/about

2.2 Microsoft Security Development Lifecycle

Prácticas del SDL

1: Establecer estándares, métricas y gobernanza de seguridad

Esta práctica se centra en actualizar y comunicar continuamente los requisitos de seguridad para reflejar los cambios en la funcionalidad y en el panorama normativo y de amenazas.

2: Requerir el uso de funciones, lenguajes y marcos de seguridad probados

Esta práctica se centra en garantizar que los equipos de desarrollo utilicen soluciones de seguridad bien establecidas y probadas.

3: Realizar una revisión de diseño segura y un modelado de amenazas

Los fallos en el diseño de seguridad pueden generar vulnerabilidades que los atacantes pueden aprovechar.

4: Definir y utilizar estándares de criptografía

La criptografía es el pilar de la seguridad informática; cualquier falla en su implementación compromete todos los demás mecanismos de protección del sistema.



5: Segurizar la cadena de suministro de software

La seguridad de una carga de trabajo depende de la seguridad de todos sus componentes.

6: Garantizar un entorno de Desarrollo seguro

La seguridad de una carga de trabajo depende de la seguridad de los entornos operativos donde se desarrolla.

7: Realizar pruebas de seguridad

Las pruebas de seguridad son fundamentales para identificar riesgos, validar el desarrollo de software y tomar decisiones informadas sobre la corrección de vulnerabilidades.

8: Garantizar la seguridad de la plataforma operativa

La seguridad de una carga de trabajo depende de la seguridad de la infraestructura operativa y la plataforma que la aloja (nube, local, híbrida, etc.).

9: Implementar monitoreo y respuesta de seguridad

Mantener una visibilidad continua tanto de las vulnerabilidades que los atacantes pueden explotar como de las anomalías que podrían indicar un ataque activo

10: Proporcionar capacitación en seguridad

Garantizar que cualquier persona en la organización que tome decisiones que afecten la seguridad de las aplicaciones comprenda las implicaciones de dichas decisiones.

2.2 Microsoft Security Development Lifecycle

Prácticas del SDL

Práctica 1: Establecer estándares, métricas y gobernanza de seguridad

Requisitos Continuos

Actualización Dinámica

Los requisitos de seguridad no son estáticos. Deben actualizarse continuamente para reflejar los cambios en la funcionalidad requerida, nuevas regulaciones y el panorama de amenazas en constante evolución.

Definición Temprana

El momento óptimo para definir la seguridad es durante las etapas iniciales de diseño y planificación. Permite a los equipos integrar controles de seguridad de forma orgánica, reduciendo drásticamente los costos de remediación y minimizando las interrupciones en entregas.

Factores que afectan los requisitos continuos



2.2 Microsoft Security Development Lifecycle

Prácticas del SDL

Práctica 1: Establecer estándares, métricas y gobernanza de seguridad

01

Identificar los estándares necesarios

Cada organización tendrá su propia definición de requisitos para los estándares de seguridad adecuados.

02

Definir los requisites de seguridad

Establecer una base de seguridad mínima que considere tanto los controles de seguridad como los de cumplimiento

03

Definir métricas e informes de cumplimiento

Es fundamental definir los niveles mínimos aceptables de calidad de seguridad y responsabilizar a los equipos del cumplimiento de dichos criterios. Realizar seguimiento con indicadores definidos KPI.

04

Crear un proceso de excepciones de seguridad

Varius duis at consectetur lorem donec massa sapien faucibus et molestie ac feugiat sed.

2.2 Microsoft Security Development Lifecycle

Prácticas del SDL

Práctica 2: Requerir el uso de funciones, lenguajes y marcos de seguridad probados

Soluciones probadas

Adoptar componentes de seguridad ya establecidos en lugar de inventar soluciones propias, lo que evita vulnerabilidades y desperdicio de tiempo.

Controles fundamentales

Estandarizar áreas críticas como autenticación, autorización y registro de auditoría (logging) mediante guías claras, reglas (guardrails) y verificación constante.

Herramientas y configuraciones

Definir una lista oficial de herramientas actualizadas y aplicar parámetros de seguridad específicos (como opciones de compilador y análisis automático).

2.2 Microsoft Security Development Lifecycle

Prácticas del SDL

Práctica 2: Requerir el uso de funciones, lenguajes y marcos de seguridad probados

01

Identidades

Asegurar de que los usuarios utilicen una autenticación sólida y que solo tengan el nivel de permisos adecuado a sus necesidades (principio de mínimo privilegio).

02

Seguridad e implementación de IA

Revisar las directrices específicas para cualquier persona que desarrolle o integrar soluciones de IA.

03

Protección de Datos

Garantizar la seguridad del contenido utilizado en las aplicaciones: Implementación segura y conexión a bases de datos, cuentas de almacenamiento, documentos no estructurados y otros aspectos más.

04

Registro y Telemetría

Proporcionar información valiosa sobre el comportamiento y el rendimiento de los sistemas y las aplicaciones.

05

Utilizar herramientas aprobadas

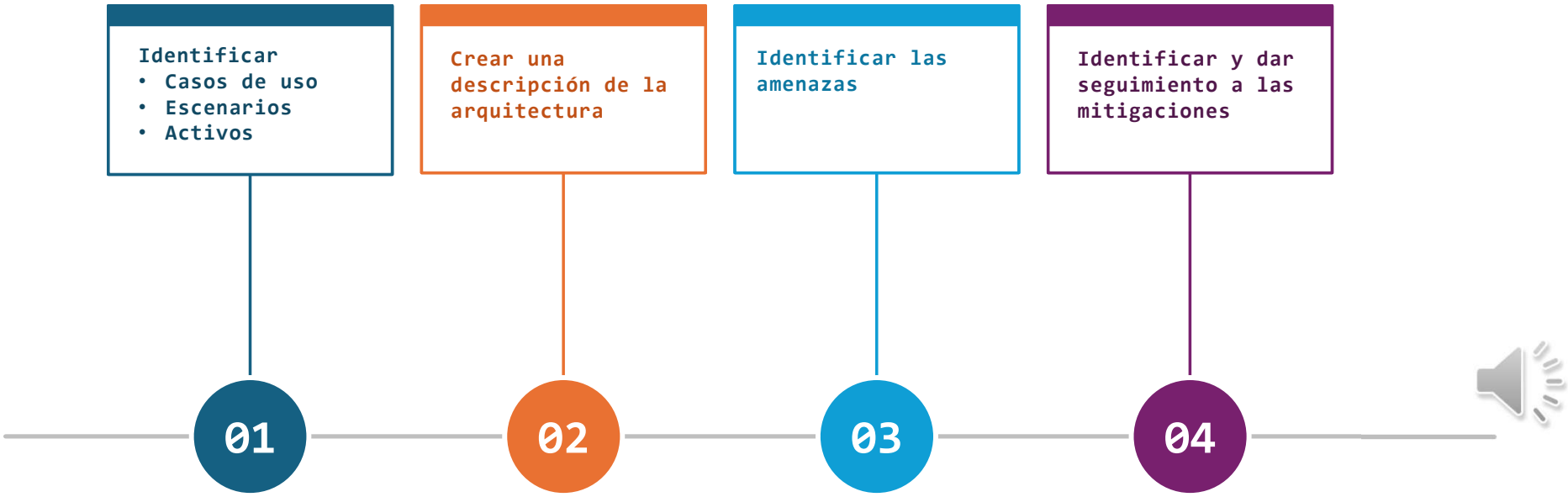
Definir y publicar una lista de herramientas aprobadas y sus comprobaciones de seguridad asociadas, como las opciones y advertencias del compilador/enlazador.

2.2 Microsoft Security Development Lifecycle

Prácticas del SDL

Práctica 3: Realizar una revisión de diseño segura y un modelado de amenazas

Proceso del Modelado de Amenazas



2.2 Microsoft Security Development Lifecycle

Prácticas del SDL

Práctica 3: Realizar una revisión de diseño segura y un modelado de amenazas

01

Identificar casos de uso, escenarios y activos

Una parte esencial del modelado de amenazas y la revisión de modelos de amenazas es comprender las funciones comerciales o "casos de uso" del sistema.

02

Descripción general de la arquitectura

Crear diagramas y tablas para representar la arquitectura de su aplicación, incluidos los subsistemas, los límites de confianza y los flujos de datos entre actores y componentes.

03

Identificar amenazas

El modelado de amenazas es más eficaz cuando la realiza un grupo de personas familiarizadas con la arquitectura del sistema y las funciones empresariales, que estén preparadas para pensar como atacantes.

04

Identificar y monitorear las medidas de mitigación

Una mitigación parcial que aumente el costo para el atacante, lo ralentice para dar tiempo a los defensores a detectarlo o limite el alcance del daño es mucho mejor que ninguna mitigación.

05

Comunicar los modelos de amenazas a las partes interesadas (stakeholders)

La elaboración de modelos de amenazas no está completa hasta que cree elementos de trabajo para registrar los hallazgos y las tareas de desarrollo y prueba relacionadas para mitigarlas.

2.2 Microsoft Security Development Lifecycle

Prácticas del SDL

Práctica 4: Definir y utilizar estándares de criptografía

Protección de datos

Es imprescindible resguardar la información tanto en reposo como en tránsito mediante una gestión adecuada de claves y certificados.

Identificación de riesgos

El modelado de amenazas es la herramienta clave para determinar qué datos específicos requieren cifrado.

Uso de estándares

Dado que es un área compleja, los desarrolladores deben contar con guías claras y evitar a toda costa crear algoritmos propios.

Bibliotecas validadas

La regla de oro es utilizar exclusivamente bibliotecas criptográficas probadas e hidrogenadas por la industria para garantizar un desarrollo seguro y actualizado.

2.2 Microsoft Security Development Lifecycle

Prácticas del SDL

Práctica 4: Definir y utilizar estándares de criptografía

01

Cifrado de datos en tránsito y en reposo

Asegurar de que los datos estén cifrados tanto en reposo como en tránsito, incluyendo información confidencial y datos de gestión y control.

02

Criptografía postcuántica (PQC)

Establecer una base de seguridad mínima que considere tanto los controles de seguridad como los de cumplimiento

03

Agilidad criptográfica

La práctica de implementar soluciones criptográficas para permitir cambios en nuevos mecanismos, algoritmos y bibliotecas criptográficas cuando sea necesario.

04

Gestión y rotación de claves y certificados de cifrado

El cifrado de datos es solo una parte de un estándar criptográfico eficaz; también es fundamental definir cómo gestionar, proteger y rotar las claves y los certificados de cifrado.

2.2 Microsoft Security Development Lifecycle

Prácticas del SDL

Práctica 5: Segurizar la cadena de suministro de software

Riesgo para terceros

La gran mayoría del software actual integra componentes comerciales y de código abierto (OSS). Es indispensable evaluar el impacto de seguridad de cada elemento antes de incorporarlo y limitar el uso de componentes de alto riesgo.

Obtención de código

Existen múltiples métodos descontrolados para consumir OSS en los equipos (clonación por Git, curl, wget, copia directa o paquetes comprimidos), lo que impide un control efectivo.

Estandarización imprescindible

Garantizar la seguridad de la cadena de suministro de OSS solo es posible unificando el proceso de consumo bajo flujos de trabajo estrictamente controlados en toda la organización.

2.2 Microsoft Security Development Lifecycle

Prácticas del SDL

Práctica 5: Segurizar la cadena de suministro de software

01

Establecer un proceso seguro de ingesta de software de código abierto

El Marco de Consumo de la Cadena de Suministro Segura (S2C2F) es un proceso de garantía de seguridad y reducción de riesgos que se centra en garantizar la seguridad de cómo los desarrolladores consumen software de código abierto.

02

Comprender las dependencias en el entorno de trabajo

Muchos proyectos de software dependen de proyectos de software de código abierto, y muchos de estos, a su vez, dependen de otros proyectos de código abierto.

03

Generar una lista de materiales de software (SBOM)

Contribuyen a la transparencia e integridad del software. Una SBOM es un documento legible por máquina que enumera todos los componentes, incluidos los de código abierto, utilizados para crear un producto.

04

Firma y validación de componentes

Esto se aplica tanto a los SBOM como a los artefactos creados por las herramientas integradas en el ciclo de vida.

2.2 Microsoft Security Development Lifecycle

Prácticas del SDL

Práctica 6: Garantizar un entorno de desarrollo seguro

Entorno de Desarrollo seguro

El sistema debe garantizar la autenticidad del sujeto y la validez de la solicitud

Estrategias

- Aplicación estricta del mínimo privilegio en todos los accesos al código fuente.
- Almacenamiento en repositories git resguardados con MFA y acceso condicional.
- Otorgar permisos JIT y JEA, revisados periódicamente.
- Separación de redes de ingeniería y verificación continua de logs.

Vulnerabilidades

- Infiltración en la cadena de suministro: Los atacantes targetean cuentas de usuario, entornos de prueba y procesos de compilación, no solo el código final.
- Ataques laterales: : Un entorno de desarrollo vulnerado facilita la intrusión a otros sistemas internos y servidores de producción.

- **POLÍTICAS DE CONFIANZA CERO (ZT)**
- **CONTROL DE VERSIONES PROTEGIDO**
- **GESTIÓN DE ACCESOS PRIVILEGIADOS**
- **SEGMENTACIÓN Y MONITOREO**

2.2 Microsoft Security Development Lifecycle

Prácticas del SDL

Práctica 6: Garantizar un entorno de desarrollo seguro

01

Adoptar un enfoque de confianza cero

Una parte esencial del modelado de amenazas y la revisión de modelos de amenazas es comprender las funciones comerciales o "casos de uso" del sistema.

02

Deshabilitar confirmaciones directas en ramas de producción

Configurar los repositorios de control de versiones para impedir que las cuentas de desarrollador realicen confirmaciones directas en ramas de producción y para exigir la revisión y aprobación del código para todas las solicitudes de extracción.

03

Implementar estaciones de trabajo con acceso privilegiado

El uso de estaciones de trabajo con seguridad reforzada ayuda a proteger a los usuarios privilegiados de los ataques de Internet y los vectores de amenazas.

04

Proporcionar estaciones de trabajo virtuales seguras

Las estaciones virtuales se pueden configurar con herramientas, código fuente y binarios pre-compilados específicos para cada proyecto, lo que permite a los desarrolladores comenzar a trabajar de inmediato y con total seguridad.

05

Implementar GitHub Codespaces

Los desarrolladores pueden crear rápidamente un Codespace con solo un IDE o un navegador y una cuenta de GitHub, y trabajar en un entorno de desarrollo compartido y seguro.

06

Entornos de implementación segura

Los desarrolladores deben en forma rápida y sencilla crear infraestructuras de aplicaciones mediante plantillas basadas en proyectos que establecen coherencia y buenas prácticas, a la vez que maximizan la seguridad.

2.2 Microsoft Security Development Lifecycle

Prácticas del SDL

Práctica 7: Realizar pruebas de seguridad

Visibilidad y toma de decisiones

Evaluar las aplicaciones permite priorizar soluciones e identificar fallas sistémicas en los procesos de desarrollo.

Integración temprana

Incorporar la seguridad desde las primeras etapas del ciclo de vida del software garantiza un impacto directo e inmediato.

Estrategia combinada

Se requiere una mezcla de enfoques automatizados (análisis estático y dinámico) y manuales (pruebas de penetración) para una cobertura efectiva.

2.2 Microsoft Security Development Lifecycle

Prácticas del SDL

Práctica 7: Realizar pruebas de seguridad

01 **Implementar SAST**

Las pruebas de seguridad de análisis estático (SAST) proporcionan un método altamente escalable de revisión de seguridad de código y ayuda a garantizar políticas de ejecución segura.

02 **Implementar DAST**

Las pruebas de seguridad de análisis dinámico (DAST) verifican la funcionalidad que solo se puede ejercer cuando todos los componentes están integrados y en funcionamiento.

03 **Ejercicios de equipo rojo / azul**

Un equipo especializado de expertos en seguridad, denominado "equipo rojo", simula ataques reales, poniendo a prueba la capacidad del "equipo azul" de servicios en la nube.

04 **Prueba de penetración de aplicaciones**

Simulan ataques reales y ponen a prueba a los equipos para detectar, proteger y recuperarse. Las pruebas de penetración son análisis de seguridad de sistemas de software realizados por profesionales de seguridad.

05 **Realizar pruebas y mediciones de seguridad continuas**

Las pruebas de seguridad continuas (CST) verifican periódicamente los problemas de seguridad y las implementaciones inseguras de terceros.

06 **Realizar pruebas de seguridad programadas**

Las pruebas de seguridad rutinarias deben realizarse con regularidad para cumplir con los requisitos de cumplimiento

07 **Implementar un programa de recompensas por detección de errores (bug bounty)**

El objetivo es descubrir vulnerabilidades significativas que tengan un impacto directo y demostrable en los sistemas.

2.2 Microsoft Security Development Lifecycle

Prácticas del SDL

Práctica 8: Garantizar la seguridad de la plataforma operativa

Dependencia del entorno

La seguridad de una carga de trabajo está supeditada a la protección integral de la plataforma que la aloja (nube, local o híbrida) y de sus componentes (identidades, redes, servidores, contenedores y dispositivos).

Impacto de una brecha

Si un atacante compromete la infraestructura de producción, obtiene control total sobre la carga de trabajo y sus datos, lo que le permite realizar movimientos laterales hacia otros sistemas internos.

Coherencia operativa

Es indispensable aplicar controles y prácticas de seguridad de forma homogénea tanto en cada carga de trabajo como en la infraestructura global.

2.2 Microsoft Security Development Lifecycle

Prácticas del SDL

Práctica 8: Garantizar la seguridad de la plataforma operativa

01 Implementar la autenticación multifactor

Implementar controles adicionales para proteger a todos los usuarios, especialmente a los administradores

02 Proteger las cuentas administrativas

Se utiliza una combinación de defensas por capas para proteger el acceso administrativo a los sistemas de producción.

03 Implementar líneas base de seguridad

Todos los entornos operativos deben tener líneas base de seguridad definidas y aplicadas.

04 Crear capas de aislamiento

Las capas de aislamiento se refieren a los distintos niveles en los que se aplican los controles de seguridad para garantizar que los sistemas se mantengan separados y seguros.

05 Utilizar computación confidencial

Aislar los datos confidenciales mientras se procesan en la nube. Las máquinas virtuales solo protegen la máquina host de la actividad maliciosa dentro de la máquina virtual.

06 Reducir la superficie de ataque

Las superficies de ataque son todos los puntos donde su organización es vulnerable a las ciberamenazas y los ciberataques.

07 Realizar pruebas de penetración en la plataforma

Pruebas de penetración en la plataforma de producción, desde centros de datos físicos hasta plataformas en la nube.

08 Implementación de terminales operativas

El control de dispositivos es fundamental, ya que un atacante con acceso a un dispositivo puede suplantar la identidad de los usuarios o robar credenciales para suplantar identidades posteriormente.

09 Mantenimiento programado

Todos los sistemas deben ser monitoreados y actualizados continuamente con las últimas actualizaciones de seguridad.

10 Protegerse contra ataques DDoS

Proporcionar mitigación en tiempo real para ataques comunes a nivel de red.

2.2 Microsoft Security Development Lifecycle

Prácticas del SDL

Práctica 9: Implementar monitoreo y respuesta de seguridad

Monitoreo y respuesta de seguridad

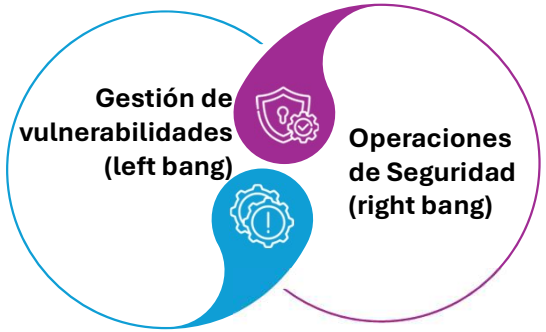
Mantener visibilidad constante sobre vulnerabilidades y amenazas activas para orientar la mitigación de riesgos y responder a ciberataques

Operaciones de Seguridad (SecOps / SOC)

Gestión activa e inmediata dedicada a la detección, respuesta y recuperación frente a incidentes en curso.

Gestión de postura o vulnerabilidades

Enfoque preventivo orientado a identificar y corregir fallos antes de que sean explotados.



2.2 Microsoft Security Development Lifecycle

Prácticas del SDL

Práctica 9: Implementar monitoreo y respuesta de seguridad

01

Detectar y abordar las amenazas de forma proactiva

Utilizar una plataforma de análisis de seguridad e inteligencia de amenazas para detectar ataques, visualizar las amenazas, realizar búsquedas proactivas y responder ante ellas.

02

Establezca un proceso estándar de respuesta a incidentes

Preparar un plan de respuesta a incidentes para ayudar a abordar las nuevas amenazas que pueden surgir con el tiempo. Debe crearse en coordinación con el Equipo de respuesta a incidentes de seguridad de productos (PSIRT) dedicado de su organización

2.2 Microsoft Security Development Lifecycle

Prácticas del SDL

Práctica 10: Proporcionar capacitación en seguridad

Responsabilidad por rol

Todos los integrantes del ciclo de vida del desarrollo (gerentes, evaluadores, usuarios) deben comprender el impacto de sus decisiones y recibir formación adaptada a su función específica.

Modelado de amenazas como competencia clave

Dado que los desarrolladores superan en número al personal de seguridad, los equipos de ingeniería deben capacitarse en modelado de amenazas desde la incorporación y mediante actualizaciones periódicas para crear sistemas seguros desde el diseño.

Aprendizaje dinámico y continuo

La seguridad es un proceso en constante evolución frente a nuevas amenazas; la formación debe actualizarse continuamente, reforzando las políticas internas y enseñando a pensar desde la perspectiva del atacante.

Fundamentos sólidos sin hiperespecialización

El objetivo no es convertir a cada colaborador en un pentester o especialista, sino garantizar que todos dominen las prácticas básicas de seguridad para su trabajo cotidiano e identidades digitales.